CampusClaw

基于 Token 的身份认证与知识库问答实现方案

一、项目概述

本项目实现了按班级隔离的教学材料系统，并在此基础上增加了 JWT Bearer Token
认证、知识库分块、三种检索模式、带来源引用的 AI 问答、教师助手配置、持久化对话和 SSE 流式回答。
系统的核心原则是：身份、角色和班级范围由服务端决定；浏览器提交的 user_id、role、class_id 和 source_id
等字段不能扩大权限；问答只能使用当前班级检索出的资料。

二、基于 Token 的身份认证

1. 登录和 Token 签发

客户端向 POST /api/login 提交 accountIdentifier 和 password。服务端从 users
表查找用户，并使用密码哈希验证。验证成功后，同时建立 Cookie Session 和 JWT Bearer 两种认证方式。

- Cookie Session 使用 HttpOnly、SameSite=Lax Cookie，保留原有浏览器兼容能力。
- JWT 使用 HS256 签名，包含 sub、jti、role、class_id、iss、aud、iat 和 exp 等字段。
- jti 经过 HMAC-SHA256 哈希后写入 access_token_sessions，数据库不保存原始 token 和原始 jti。
- 登录响应返回 accessToken、tokenType 和 expiresAt，浏览器将 accessToken 保存在 sessionStorage 中。

2. 受保护请求如何识别用户

服务端认证中间件位于 src/auth.ts。请求包含 Authorization header 时，服务端优先解析 Bearer
Token；只有请求没有 Authorization header 时，才使用 Cookie
Session。这样可以避免一个请求同时携带两个不同身份。

1. 解析 Authorization: Bearer 。
2. 使用 HS256 验证签名，并检查 issuer、audience 和过期时间。
3. 根据 jti 哈希查询 access_token_sessions，检查 token 是否存在、是否过期、是否被撤销。
4. 将 JWT 的 sub、role、class_id 与数据库中的当前用户进行比对。
5. 验证成功后生成 request.sessionIdentity，后续路由只使用这个服务端身份。

Token 无效、篡改、过期、撤销或身份不匹配时返回 HTTP 401。学生调用教师接口时返回 HTTP
403。登出时会清除 Cookie，并撤销当前 Bearer Token。

三、班级隔离和材料数据

用户登录后，request.sessionIdentity.classId
会作为材料、知识条目、chunk、检索结果和对话查询的范围条件。服务端查询资源时同时比较资源的
class_id。对象不存在和对象属于其他班级时返回同形 404，避免泄露跨班资源是否存在。 A 班用户不能通过修改
URL、请求体或查询参数访问 B 班材料。客户端提供的 class_id、user_id、role 和 source_id
都不会覆盖服务端身份。 上传材料后的数据变化如下：

1. 文件：校验 UTF-8、扩展名、非空和大小后，写入持久化材料目录。
2. materials：保存上传者、class_id、原始文件名、storage_key、文件类型和文件大小。

3. knowledge_entries：保存解析后的原始内容和顺序，原文不会被分块过程改写。

4. knowledge_chunks：保存 chunk
文本、材料、知识条目、班级、序号、字符起止偏移和索引状态。

5. knowledge_chunk_embeddings：记录 embedding 的 pending、ready 或 failed
状态，并支持失败重试。

四、知识库分块和检索

1. 分块策略

src/knowledge/chunker.ts 提供三种分块方式。auto 按最大字符数和 overlap
窗口切分，并尽量在换行或句号附近断开；separator 按受限长度的字面分隔符切分；markdown_heading
识别一级到三级 Markdown 标题，并对过长章节继续切分。 分块索引只生成新的索引记录，不修改
knowledge_entries 中的原始内容。每个 chunk 都记录字符 offset，因此回答可以回到材料中的具体片段。

2. 三种检索模式

- keyword：使用 PostgreSQL 全文检索和当前班级过滤，不需要调用 embedding provider。
- vector：为问题生成 query embedding，使用 pgvector 相似度、模型身份和阈值过滤。
- hybrid：分别执行 keyword 和 vector 检索，再使用 RRF k=60 融合、去重和稳定排序。

POST /api/search 接收 q、mode、limit 和
offset。服务端忽略客户端提交的身份和班级字段，结果只来自当前登录用户的班级。

五、基于知识库的 AI 问答

1. 问答流程

1. 从服务端认证身份取得 classId。

2. 对当前班级执行 hybrid 检索，最多选取四个 chunk。

3. 把文件名、chunk 序号、字符偏移和原文片段组成编号证据。

4. 读取当前班级的 system prompt 和 guided-solving 配置。

5. 加入受限的历史 user/assistant 消息，客户端不能注入 system 消息。

6. 只有存在检索证据时，才调用 OpenAI-compatible chat provider。

7. 返回 answer 和 citations，回答使用 [1]、[2] 等标记对应来源。

2. 无命中和 provider 失败

如果当前班级没有命中资料，接口固定返回“资料中未找到相关内容”，citations
为空，并且不会调用聊天模型。这样可以避免模型脱离本班资料自由回答。 embedding 或聊天 provider
发生错误时，服务端返回通用 HTTP 503，不把 provider 的内部错误、请求内容或密钥暴露给浏览器。
例如问题“磁铁能吸木块吗？”会返回带有 [1] 的回答，并附带
A班-小学科学课程资料.md、切片序号、偏移范围和原文 excerpt。

六、教师配置、对话和 SSE

assistant_configs 按 class_id 保存教师配置。教师可以修改 system_prompt 和
guided_solving_enabled，学生只能读取和使用，不能通过直接调用接口修改。 conversation 和

conversation_messages 同时保存 user_id 和
class_id。创建、读取和追加消息时，服务端会验证当前用户是否拥有该对话。其他用户或其他班级只能得到 404。 POST /api/conversations/:conversationId/stream 返回 SSE 事件。事件顺序通常是 meta、citation、delta、done；出现故障时返回 error。成功回答才会把 assistant message 标记为 done，失败时不会伪造成功结果。

七、浏览器实现和作业截图

登录成功后，浏览器把 accessToken 放入 sessionStorage。受保护的 fetch、上传
XHR、搜索、问答、配置、conversation 和 SSE 请求都附加 Authorization: Bearer。页面显示的用户身份来自 /api/me 的服务端结果，不信任浏览器存储中的 role 或 classId。 教师问答截图应包含 teacher-a、teacher、A 班、问题、回答、[1] 引用、材料名和来源片段。 Token 截图可以在 Network 面板选择 /api/me、/api/search 或 /api/ask，在 Request Headers 中查看 Authorization: Bearer。提交前必须打码完整 token 和 Cookie。
知识问答模式通常只看到 /api/ask，因为检索在服务端内部完成；如果要看到
/api/search，需要点击“知识检索”标签，输入“磁铁 木块”并执行搜索。

八、安全边界和非目标

- 不实现注册、找回密码、刷新 token、OAuth、SSO 或平台管理员。
- 不实现作业批改、技能市场、MCP、队列、多副本高可用或公网部署。
- 日志、数据库和接口响应不保存或输出原始 JWT、jti、provider key、密码和完整 provider payload。
- 截图中的 Authorization 和 Cookie

属于临时凭据，提交前必须打码；如果已经公开，应退出登录或重启服务使其失效。

九、验收结论

当前实现已通过项目自动化测试、TypeScript 构建、OpenSpec 严格校验和 Docker Compose
端到端验收。已验证 JWT 登录、/api/me 身份恢复、A 班混合检索、带引用的知识问答、无命中不调用模型、SSE meta/citation/delta/done 事件和班级边界控制。 仓库地址：https://github.com/stanleyll/forth-lesson